NexusAI business case and ROI

Julian Calvo. AAI6850, Module 15 capstone. August 2026.

Everything here is a model, not a forecast. No customer has been signed and no revenue has happened. Every line in `docs/roi_model.csv` is either tied to a contract constant, tied to a cited source, or flagged as an unsourced estimate.

1. The problem

Phishing is still the way most organisations get breached, and the cost per incident is large. IBM's 2025 Cost of a Data Breach report puts the average breach with phishing as the initial vector at about USD 4.8M.

There are vendors selling detection models. The trouble is on the buying side:

1. You can't verify an accuracy claim before you pay. The vendor measured it, on data they chose.
2. Models decay. The number in the datasheet was true at some point and nobody tells you when it stops being true.
3. Buying one is a procurement cycle. You can't try a model on a monthly licence without legal getting involved.
4. Transacting on a public chain means publishing who you are and what you paid.

2. What the mechanism does about each

Friction	Mechanism	Where in the code
Unverifiable claims	Oracle committee measures on a secret holdout, contract takes the median	`AIPerformanceOracle`
Model decay	Circuit breaker plus a per-listing accuracy floor that blocks sales	`AIModelMarketplace.purchaseLicence`
Procurement friction	Per-term licences settled on chain, 7-day dispute window with escrow	`AIModelMarketplace`
Disclosure	Merkle selective disclosure, commit-reveal auctions	`ComplianceRegistry`, `SealedBidLicenceAuction`
Vendor has nothing at risk	Slashable bond, refund on a lost dispute	`StakingVault`

3. Who buys

Mid-to-large enterprises with a security team and a compliance obligation, in regulated sectors, who already buy detection tooling and would prefer to pay per term than per seat. Model providers are the other side: small ML teams who can build a good classifier and have no distribution.

4. How the protocol makes money

5% protocol fee on each licence sale. 30% of that is burned, 70% goes to the treasury. Contract ceiling on the fee is 10%. The sealed-bid auction currently takes no protocol fee at all, which is a gap in the model and in the code, and I've flagged it as such in the CSV.

Staking yield comes mostly from the treasury share, so it tracks actual volume rather than emissions.

5. Base case

Modelled on 24 active listings in year one growing to 800 by year five, and 6 licences per listing per year growing to 16, at an average licence price of USD 12,500.

USD	Y1	Y2	Y3	Y4	Y5
Active listings	24	96	240	480	800
Licences sold	144	864	2,880	6,720	12,800
GMV	1,800,000	10,800,000	36,000,000	84,000,000	160,000,000
Protocol revenue	90,000	540,000	1,800,000	4,200,000	8,000,000
Opex	2,120,000	2,630,000	3,290,000	3,660,000	4,030,000
Net cash flow	(2,030,000)	(2,090,000)	(1,490,000)	540,000	3,970,000
Cumulative	(2,630,000)	(4,720,000)	(6,210,000)	(5,670,000)	(1,700,000)

Opex is mostly engineering (5 to 11 blended FTE at around USD 240,000 loaded), plus two full audits before mainnet, oracle infrastructure, legal, and business development.

6. Valuation

Discount rate 30%, which is a seed-stage convention and not sourced. Terminal growth 5%.

	Bear	Base	Bull
Y3 GMV	4,860,000	36,000,000	180,000,000
NPV @ 30%	(6,034,422)	1,672,676	50,863,559
NPV excluding terminal value	(6,034,422)	(2,818,117)	13,575,272
NPV @ 20%	(7,382,086)	3,951,453	75,987,793
NPV @ 40%	(5,073,414)	319,667	34,938,989
IRR	no sign change	43.3%	176.1%
Peak deficit	(12,351,400)	(6,210,000)	(3,960,000)

The base case is NPV-positive only because of terminal value. On operating cash over five modelled years it's USD 2.82M underwater in present value terms. The +1.67M is really a statement about the terminal assumption.

7. Sensitivity

All flexed against base-case year three, one driver at a time, opex held flat.

Take rate:

Take rate	Y3 revenue	Y3 net
3%	1,080,000	(2,210,000)
5% (default)	1,800,000	(1,490,000)
7.5%	2,700,000	(590,000)
10% (ceiling)	3,600,000	310,000

Active listings:

Listings	Y3 GMV	Y3 net
90	13,500,000	(2,615,000)
240 (base)	36,000,000	(1,490,000)
480	72,000,000	310,000
800	120,000,000	2,710,000
1,200	180,000,000	5,710,000

Take rate is the weakest lever. Even at the contract maximum, year three barely turns positive, and raising the fee is the change most likely to send both sides somewhere cheaper. The protocol needs roughly double its base-case listings or double its demand density to break even in year three. So the fee isn't the lever. Getting more listings is.

8. Buyer-side ROI

This is the stronger of the two cases.

Assumptions: a 10,000-employee enterprise, USD 4.8M average cost when phishing is the initial vector (IBM 2025), and a 12% annual probability of a material phishing-initiated breach. That 12% is an estimate, not sourced, and I modelled 8% to 20%.

Expected annual loss at 12% is USD 576,000. A licence at USD 12,500 for a model that reduces the incident rate needs only a small relative lift to pay for itself. Break-even is roughly a 2.2% reduction in expected loss, which is a low bar for a detection layer that measurably works.

The mechanism helps the buyer beyond the raw expected value. The accuracy floor means the buyer stops paying automatically when the model stops working, rather than at renewal. The escrow and dispute window mean a bad month is refundable. The provider bond means the vendor has money at risk in a way a normal software contract doesn't provide.

9. Risks

Risk	Mitigation
Nobody lists models	Seed the marketplace with the phishing model and grant-funded providers
Oracle reporters collude	Median aggregation, circuit breaker, permissioned and identifiable reporters. Long term, move to a DON
Regulatory treatment of the token	Utility framing, no public sale modelled, legal opinion budgeted in year zero
Bridge compromise	Trusted remotes and nonce checks in the registry, plus a real audited adapter before mainnet
Accuracy claims don't survive real data	Re-run on real corpora before any commercial claim. Already disclosed
Take rate pressure from a cheaper venue	The verification mechanism is the hard part to copy, so compete there rather than on fee

10. Adoption plan

Phase 1, months 0 to 6. Pilot. Ship the phishing model as the first listing. Recruit three to five reporters from academic security groups. Two design partners on free licences in exchange for evaluation feedback. Independent audit round one.

Phase 2, months 6 to 15. Testnet consortium. Ten to twenty listings, real CCIP adapter, monitoring stack live, second audit. Deployment and the governance handoff are already done on Sepolia and Hoodi.

Phase 3, months 15 to 36. Mainnet. Open provider onboarding, treasury-funded staking rewards, arbitration multisig replacing the single arbiter, and the cross-chain revocation work from R-01.

11. Conclusion

The buyer-side case holds up on its own and doesn't need the token to do anything. The protocol side depends on volume and is underwater once you strip out terminal value. What I'd want at this stage is phase-one funding, not a mainnet launch.

References

1. IBM, Cost of a Data Breach Report 2025
2. Verizon Data Breach Investigations Report
3. Contract constants in `contracts/` and the assumption sheet in `docs/roi_model.csv`